Saadhya Ayurvedalaya

Clinic Platform MVP — Technical Architecture Summary

FRAMEWORK	DATABASE	AUTH	HOSTING	DOMAIN	REPO
Next.js 14 (Pages Router)	Supabase (PostgreSQL)	Supabase Email OTP	Vercel	saadhyaayurvedalaya.com	github.com/sathwiik/sadhya-ayurvedalaya

1. TECHNOLOGY STACK

LAYER	TECHNOLOGY	PURPOSE
Frontend Framework	`Next.js 14` (Pages Router)	SSR, SSG, API routes, ISR
Language	TypeScript	Type safety throughout
Styling	Tailwind CSS 3	Utility-first, mobile-first design
Database	Supabase PostgreSQL	All clinic data storage
Authentication	Supabase Auth (Email OTP)	Passwordless doctor login
PDF Generation	`@react-pdf/renderer`	Prescription slips, billing receipts
Token Generation	`nanoid` (21 chars)	Patient appointment access links
SMS	MSG91 HTTP API v5	Appointment confirmations, reminders
Backup	Google Drive API (`googleapis`)	Monthly JSON export via service account
Scheduling	Vercel Cron	Daily SMS reminders + monthly backup
Markdown	`react-markdown`	Blog post rendering

2. DATABASE SCHEMA

7 tables in Supabase PostgreSQL with Row Level Security. All admin access requires authenticated session. Token-based patient access is handled in API routes using the service role key.

TABLE	PRIMARY KEY	KEY COLUMNS	NOTES
patients	UUID	name, phone (UNIQUE), dob, address, aadhaar_last4	Last 4 digits of Aadhaar only
appointments	UUID	patient_id, appt_date, time_slot, mode, status, token (UNIQUE), token_expires_at	Hub table — all records link here
prescriptions	UUID	appointment_id, drug_name, dosage, frequency, days, notes	Many per appointment
billing	UUID	appointment_id (UNIQUE), fee, items (JSONB), paid, payment_mode, paid_at	Auto-created on appointment create
medicine_stock	UUID	drug_name (UNIQUE), quantity, unit, low_stock_threshold, price	Used for prescription autocomplete
content_posts	UUID	title, body, published, created_at	Public anon read if published=true
settings	INTEGER (always 1)	clinic_name, doctor_name, address, phone, email, consent_text	Single row, always id=1

RLS POLICIES

- Authenticated (doctor): full access to all tables
- Anon: read-only on `content_posts` where `published=true`
- Token-based access: handled server-side with service role key — bypasses RLS intentionally

INDEXES

- `appointments(token)` — fast token lookup
- `appointments(appt_date)` — date range queries
- `appointments(patient_id)` — patient history

- `patients(phone)` — UNIQUE constraint + lookup

3. APPLICATION ARCHITECTURE

PUBLIC SURFACE

- **/** — Homepage (SSR, settings + posts)
- **/blog** — Published posts list (SSR)
- **/blog/[id]** — Post with Markdown (ISR, revalidate 300s)
- **/appt/[token]** — Patient token page (SSR, consent flow)
- **/login** — Doctor email OTP login

ADMIN SURFACE (AUTH-GUARDED)

- **/admin** — Dashboard
- **/admin/patients** — List + detail
- **/admin/appointments** — List + new + edit
- **/admin/prescriptions/[id]** — Drug management
- **/admin/stock** — Medicine inventory
- **/admin/billing** — Billing + receipts
- **/admin/posts** — Blog CMS
- **/admin/settings** — Clinic config

API Routes

ROUTE	METHOD	AUTH	DESCRIPTION
`/api/appointments/create`	POST	Session	Upsert patient → create appt → create billing → send SMS
`/api/token/[token]`	GET	None (service role)	Validate token, return safe appointment data
`/api/consent`	POST	None (service role)	Set consent_given=true, consent_at=now()
`/api/sms/reminder`	GET	CRON_SECRET	Send next-day reminders, set reminder_sent=true
`/api/backup/run`	GET	CRON_SECRET	Export all tables to JSON → upload to Google Drive

4. KEY DATA FLOWS

Create Appointment Flow

1. Doctor fills 2-step form (patient phone lookup → appointment details)
2. POST /api/appointments/create (session-authenticated)
3. Service role client: INSERT patients ON CONFLICT (phone) DO UPDATE → get patient_id
4. Generate nanoid(21) token, set token_expires_at = now() + 30 days
5. INSERT appointments (patient_id, date, time, mode, complaint, token)
6. INSERT billing (appointment_id, patient_id, fee=0, items=[])
7. Send SMS via MSG91 with token link to patient phone
8. Return { appointment_id, token_url } → display to doctor with "Resend SMS" option

Patient Token Page Flow

1. Patient opens /appt/[token] (from SMS link)
2. getServerSideProps: calls /api/token/[token] with service role key
3. API validates: token exists AND token_expires_at > now()
4. Returns safe fields only: name, date, time, mode, doctor name, complaint, diagnosis (if completed), prescriptions (if completed), follow_up_date — NEVER returns phone, Aadhaar, billing, clinical notes

5a. If consent_given=false → render ConsentModal (full-page overlay, cannot dismiss by clicking outside)
  — "Yes" → POST /api/consent → hide modal, show full view
  — "No" → hide modal, show minimal view (date, time, clinic name, doctor name only)

5b. If consent_given=true → show full view directly (returning visitor)

Cron Jobs (Vercel)

SCHEDULE	ROUTE	ACTION
Daily 04:00 UTC (09:30 IST)	`/api/sms/reminder`	Query appts where appt_date=tomorrow AND status=scheduled AND reminder_sent=false → send SMS → set reminder_sent=true
1st of month 01:00 UTC	`/api/backup/run`	Fetch all tables → build JSON → upload to Google Drive as saadhya_backup_YYYY_MM.json

5. SECURITY MODEL

AUTHENTICATION

- Doctor: Supabase email OTP (magic link) — no password
- Account created once manually in Supabase dashboard
- `middleware.ts` protects all `/admin/*` routes — redirects to `/login` if no session
- Cron routes verified by `Authorization: Bearer CRON_SECRET` header

CLIENT ISOLATION

- `lib/supabase.ts` — anon key, browser-safe
- `lib/supabaseAdmin.ts` — service role key, API routes ONLY
- Service role key is NEVER imported in any page or component file
- HTTPS enforced by Vercel automatically

DATA PRIVACY

- Aadhaar: last 4 digits only — full number never accepted or stored anywhere
- Token page: appointment_id never exposed to client
- Token page: clinical_notes, phone, billing, Aadhaar never returned
- Patient consent tracked: consent_given + consent_at per appointment

INPUT VALIDATION

- Phone: stripped of spaces and leading zeros, stored as 10-digit string
- All forms: required fields validated client-side AND server-side
- Aadhaar_last4: CHECK constraint (length = 4) at DB level
- Appointment status: CHECK constraint for valid enum values

Excluded from MVP: Online payments · Video calls · Multiple staff accounts · Patient self-registration · PDF uploads · WhatsApp · Push/email notifications · Patient-initiated booking

6. COMPONENT ARCHITECTURE

COMPONENT	TYPE	DESCRIPTION
`AdminLayout.tsx`	Layout	Sidebar nav (desktop) + hamburger (mobile), auth guard on every mount, logout button, active link highlighting
`PublicLayout.tsx`	Layout	Header + footer for all public-facing pages
`ConsentModal.tsx`	UI	Full-screen overlay, cannot dismiss by clicking outside, two explicit action buttons only
`PrescriptionPDF.tsx`	PDF	A5 size (148×210mm) prescription slip: clinic header, patient info, drug table, doctor signature line

7. DESIGN SYSTEM

ROLE	CLASS / COLOUR	USAGE
Primary	`green-700` (#15803d)	Buttons, links, active sidebar state, headings
Accent	`amber-600` (#d97706)	Badges, highlights, low-stock indicators
Background	`gray-50`	Page backgrounds
Cards	`white` + `gray-200` border	All cards, forms, modals — rounded-lg
Danger	`red-600`	Delete actions, warning boxes
Status: Scheduled	blue	Appointment status badge
Status: Completed	green	Appointment status badge
Status: Cancelled	gray	Appointment status badge
Status: No-show	amber	Appointment status badge

Font: Inter (Google Fonts, loaded via _document.tsx). No animations. All admin tables wrapped in `overflow-x-auto` for mobile scroll. Badge shape: `rounded-full px-2 py-0.5 text-xs font-medium`.

8. ENVIRONMENT VARIABLES

VARIABLE	WHERE USED	NOTES
`NEXT_PUBLIC_SUPABASE_URL`	Browser + server	Supabase project URL
`NEXT_PUBLIC_SUPABASE_ANON_KEY`	Browser + server	Safe for client — RLS enforced
`SUPABASE_SERVICE_ROLE_KEY`	API routes only	NEVER expose to client
`MSG91_AUTH_KEY`	API routes only	SMS provider auth
`MSG91_SENDER_ID`	API routes only	SAADHY (6 chars max)
`MSG91_TOKEN_TEMPLATE_ID`	API routes only	DLT-approved template for appt link
`MSG91_REMINDER_TEMPLATE_ID`	API routes only	DLT-approved template for reminder
`GOOGLE_DRIVE_FOLDER_ID`	Backup cron	Target Drive folder for backups
`GOOGLE_SERVICE_ACCOUNT_JSON`	Backup cron	Full JSON string of service account key
`NEXT_PUBLIC_SITE_URL`	Browser + server	https://saadhyaayurvedalaya.com
`CRON_SECRET`	Cron API routes	Bearer token to authenticate Vercel cron calls